

By invitation only

Your Linux install has two files located in */etc*, which enable you to selectively allow and ban other computers and networks. Start with the */etc/hosts.deny* file. Open it in an editor and add this line:

```
ALL:ALL EXCEPT localhost
```

This bans all services—the ‘ALL’ bans all hosts, and the ‘ALL EXCEPT’ exempts your own machine. Now, to allow access selectively, open the */etc/hosts.allow* file, and allow selected hosts to access services. For instance, if you want all computers on your private network—like 192.168.*.*—to SSH into your machine, add the line:

```
sshd:192.168.
```

This will allow all computers on the 192.168.*.* subnet to access the sshd service. Remember, the hosts file alone is not sufficient. “It’s too easy to spoof and gain access. It makes sense to tweak both this and the firewall”, says Chandrasekar—which brings us to finding out how secure your machine really is.

Kernel support

There are a couple of kernel-level features that help you secure your rig. These prevent IP address spoofing, and also prevent a common DoS-style attack.

Using IP spoofing, an intruder sends out data packets that claim to be from some other host—this conceals the intruder’s identity. The kernel supports Source Address Verification, which can repulse such attacks. By default, this is disabled; navigate down to */proc/sys/net/ipv4/conf* and inspect the directory. All your network interfaces

will be listed here. Under ‘all’, Proc file settings common to all interfaces are found, so choose that. To enable Source Address Verification for all listed interfaces, type in

```
echo 1 > /proc/sys/net/ipv4/conf/all/rp_filter
```

To turn them on selectively, choose the right interface, say, eth0, and type in

```
echo 1 > /proc/sys/net/ipv4/conf/eth0/rp_filter
```

It’s audit time

Linux features several tools that show you how secure your computer is. Start with the basic ‘ps’ tool to view all processes. After this, the ‘netstat’ tool will show you all open and closed connections. The ‘-a’ switch shows the status of all ports; the ‘-p’ switch shows the PID and name of the program that accessed the port. You should see a full list of all the programs that are setting connections; use this with the ‘Nmap’ tool (see box ‘The Toolbox’ on page 109) and terminate all offending pro-

grams. If the services need to be shut down, do so using the Service Configuration applet. Finally, make any required changes to the iptables, and save all your changes.

Play ball

Here’s a little true story to prove that danger is not just limited to the Internet.

To check out the security of our test rig, we formatted our disk and loaded Red Hat Linux 9. Then we tweaked the firewall, and the machine was denied access to the Net.

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State
tcp	0	0	0.0.0.0:1024	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:1025	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:648	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:8080	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:8080	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:111	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:6000	0.0.0.0:*	LISTEN
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN
tcp	0	0	127.0.0.1:631	0.0.0.0:*	LISTEN
tcp	0	0	127.0.0.1:25	0.0.0.0:*	LISTEN

Use the netstat -puna option and get to know which program is talking to which server

Dos and Don'ts

Dos:

- ✓ Ensure that you use a non-superuser account for everyday work
- ✓ Keep making regular backups
- ✓ Monitor your logs routinely—don't wait for security-related incidents to happen to start scanning them
- ✓ Update software regularly; at the least, install all security updates
- ✓ Keep the firewall, antivirus and other security software up at all times

Don'ts

- ✗ As far as possible, don't allow remote access; if you must grant remote access, only allow SSH-2
- ✗ Don't install binaries without checking the signatures that accompany them
- ✗ Don't set easy passwords
- ✗ Don't let unnecessary services run. Turn them on when needed and turn them off once you're done
- ✗ Don't tell anyone your root password

We allowed sshd to run, and allowed the entire local LAN subnet access to it via SSH2. Within 12 hours of the install, the machine managed to attract four trojans. Even though there are over 200 hosts on the subnet, this machine was still targeted! Of course, setting the root password to ‘rootuser’ probably wasn’t a great idea in the first place.

Moral of the story: it’s entirely cloak and dagger, good guys perennially fighting the bad guys. So, secure your computer as you go online—and please don’t use idiotic passwords. ■

SRINIVASAN RAMAKRISHNAN

Srinivasan_ramakrishnan@thinkdigit.com